

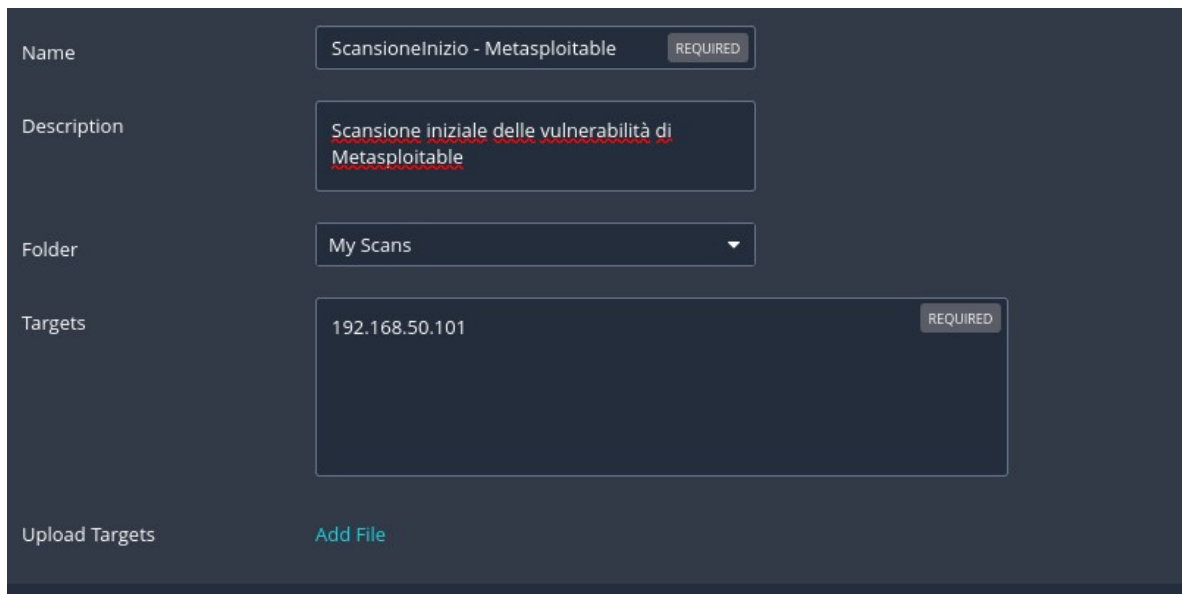
W12D4 - Analisi delle vulnerabilità e azioni di rimedio

Scansione iniziale

Ignazio Guttadauro

1. Obiettivo della scansione

Come prima cosa ho configurato una scansione Nessus sul target Metasploitable 192.168.50.101. Ho utilizzato il template Basic Network Scan con CVSS v3.0 per verificare quali vulnerabilità erano presenti prima di effettuare qualsiasi modifica.



The screenshot shows the Nessus configuration interface for a new scan. The fields are as follows:

- Name:** ScansioneInizio - Metasploitable (REQUIRED)
- Description:** Scansione iniziale delle vulnerabilità di Metasploitable
- Folder:** My Scans
- Targets:** 192.168.50.101 (REQUIRED)

At the bottom, there are buttons for "Upload Targets" and "Add File".

Figura 1 - Configurazione della scansione iniziale sul target 192.168.50.101.

2. Risultati generali

Al termine della scansione Nessus ha mostrato 64 voci nella sezione Vulnerabilities. I risultati comprendevano 9 Critical, 5 High, 22 Medium, 8 Low e 129 Informational. Per l'esercizio mi sono concentrato sulle vulnerabilità Critical e ne ho scelte tre da correggere.

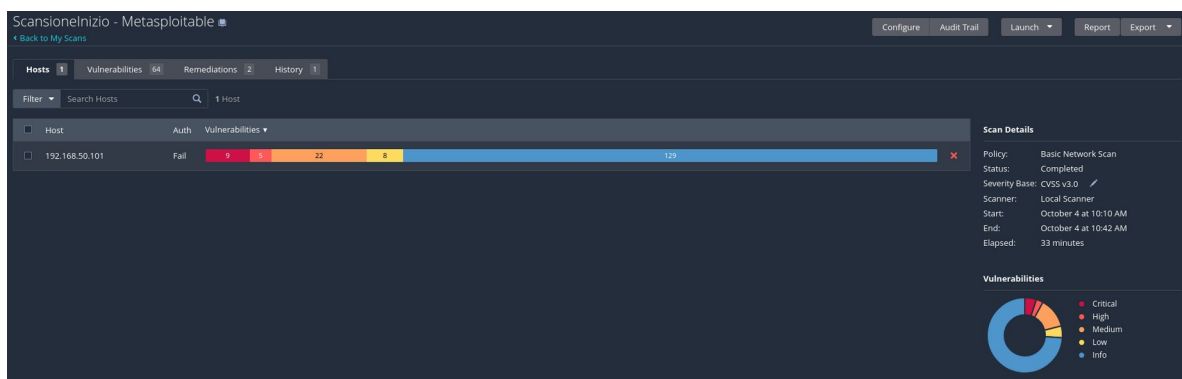


Figura 2 - Riepilogo della scansione iniziale Nessus.

Sev ▼	CVSS ▼	VPR ▼	EPSS ▼	Name ▲	Family ▲	Count ▼	⚙
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	🔄 ✎
☐ CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	🔄 ✎
☐ CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	🔄 ✎
☐ CRITICAL	9.8			Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1	🔄 ✎
☐ CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	🔄 ✎
☐ CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	🔄 ✎

Figura 3 - Principali vulnerabilità Critical rilevate.

3. Vulnerabilità critiche selezionate

3.1 VNC Server 'password' Password - CVSS 10.0

La prima vulnerabilità scelta riguarda il servizio VNC sulla porta TCP 5900. Nessus è riuscito ad autenticarsi usando la password predefinita "password". Questo significa che il servizio era protetto da una credenziale troppo semplice e facilmente utilizzabile per ottenere accesso remoto al desktop.

ScansioneInizio - Metasploitable / Plugin #61708
Configure
Audit Trail

Back to Vulnerabilities
Hosts 1
Vulnerabilities 64
Remediations 2
History 1

CRITICAL VNC Server 'password' Password
< >

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port ▲ Hosts
5900 / tcp / vnc 192.168.50.101

Figura 4 - Dettaglio Nessus della vulnerabilità VNC.

3.2 Bind Shell Backdoor Detection - CVSS 9.8

La seconda vulnerabilità era presente sulla porta TCP 1524. Nessus ha rilevato una shell raggiungibile senza autenticazione ed è riuscito a eseguire il comando id ottenendo uid=0(root) e gid=0(root). La shell permetteva quindi di eseguire comandi con privilegi di root.

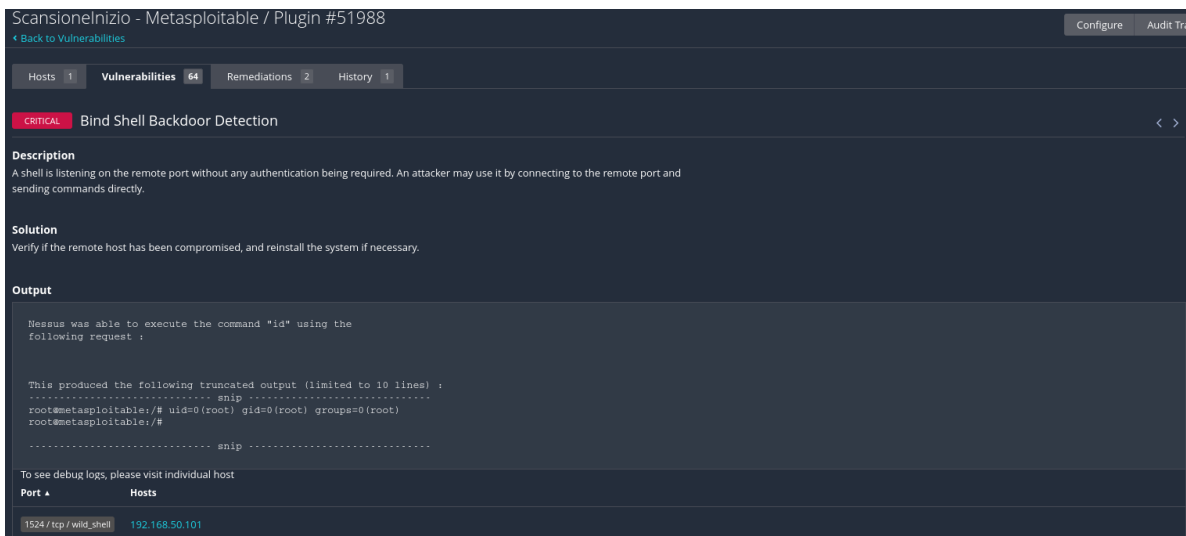


Figura 5 - Dettaglio Nessus della Bind Shell.

3.3 Apache Tomcat AJP Connector Request Injection (Ghostcat) - CVSS 9.8

La terza vulnerabilità scelta è Ghostcat, rilevata da Nessus sul connettore AJP di Apache Tomcat. Il servizio AJP era esposto e la vulnerabilità poteva permettere l'accesso a file dell'applicazione e, in alcune configurazioni, portare ad attacchi più gravi.

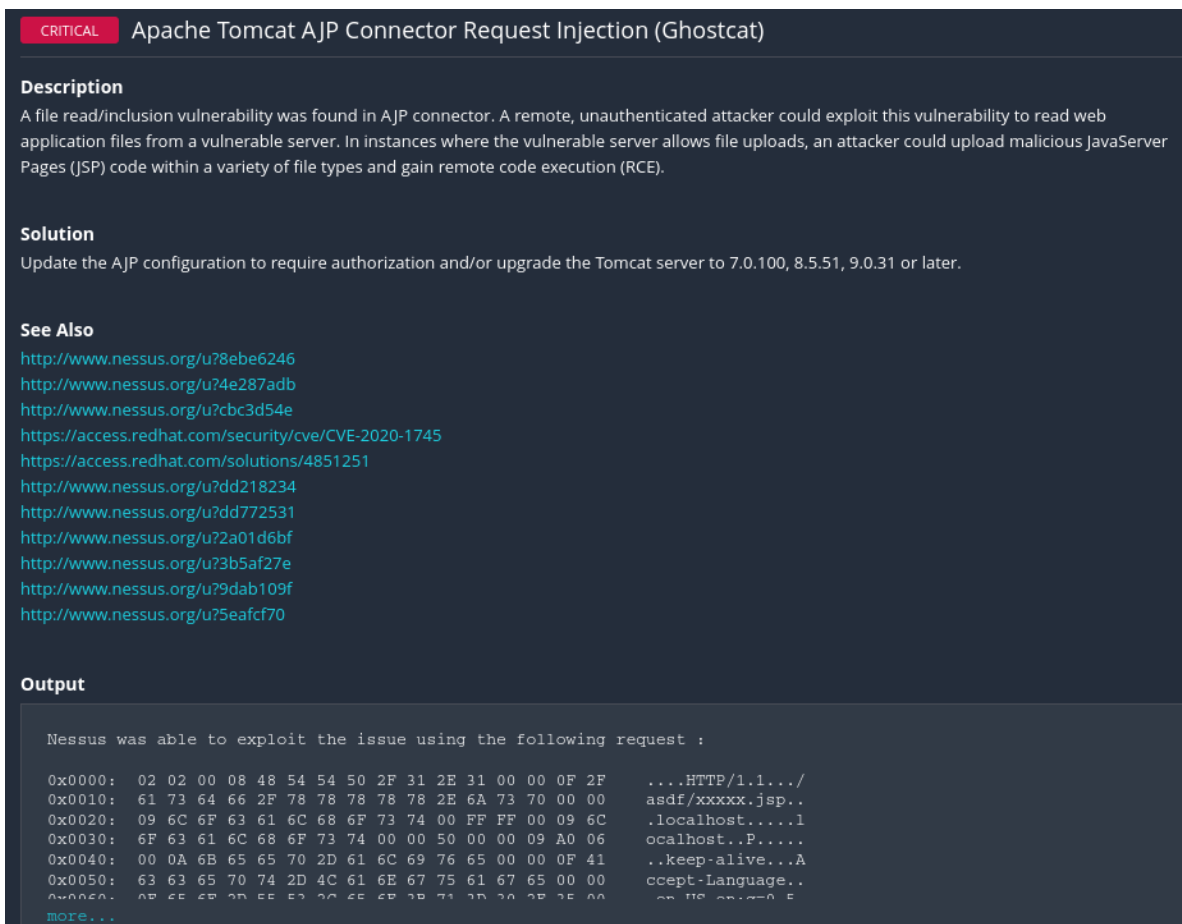


Figura 6 - Dettaglio Nessus della vulnerabilità Ghostcat.